PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

# Stratégie de défense en profondeur

03-150 ANSSI - Défense en profondeur — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

**À RETENIR**

1. La barrière se décline en protection avant l'attaque, défense pendant l'attaque, et résilience après l'attaque.
2. L'efficacité de la stratégie repose sur la multiplicité, l'indépendance et la robustesse des barrières et des mesures.
3. Une mesure est l'unité élémentaire, organisationnelle, technique ou opérationnelle, participant à la couverture d'un objectif de sécurité.

## Principes de la défense en profondeur

| Notion | À retenir |
|---|---|
| Structure d'une barrière | S'articule selon le **rôle** (quoi : avant, pendant, après l'attaque), le **placement** (où : utilisateurs, locaux, identités, réseaux, équipements, applications, données) et l'**implémentation** (comment). |
| Critères d'efficacité | La **multiplicité** (remparts successifs/autonomes/variés), l'**indépendance** (socles technologiques distincts sans faiblesses partagées) et la **robustesse** (résistance aux contournements). |
| Adaptation au contexte | Les mesures dépendent du **niveau d'exposition**, de la **criticité** et des **scénarios de risque** retenus (un exemple ne traite qu'un seul scénario). |

## Mise en œuvre contre un rançongiciel

| Notion | À retenir |
|---|---|
| Hameçonnage | Utiliser une **passerelle entrante** pour analyse **statique (signature)** et **dynamique (sandbox)**, avec règles de détection à jour. |
| Logiciel malveillant | Sensibiliser régulièrement et réaliser des **campagnes internes d'hameçonnage** pour tester le comportement. |
| Installation d'outils | Appliquer le **moindre privilège** (pas de droits d'administration), **correctifs à jour**, analyse comportementale (**EDR**) et règles de détection à jour. |
| Commande et latéralisation | Pour le C2 : **serveur mandataire**, **résolveur DNS en DMZ** (non contournables) et règles de filtrage à jour. Pour la latéralisation : **comptes d'administration dédiés** et **audits réguliers** de l'annuaire. |
| Perte de données | Mécanisme de **sauvegarde** avec au moins **une copie hors ligne** et tests réguliers de sauvegarde/restauration. |

## Exemples de barrières génériques

| Notion | À retenir |
|---|---|
| Authentification utilisateur | **Multi-facteur** (multiplicité), **jeton physique indépendant** du poste (indépendance), **défi-réponse cryptographique** et **secrets dimensionnés** (robustesse). |
| Analyse des flux | **Multiplicité des points** de collecte/analyse (multiplicité), **alertes centralisées** sur serveurs séparés et **sondes derrière TAP physiques** (indépendance), **règles de détection à jour** et **alertes fiabilisées** (robustesse). |
| Site de repli à froid | **Redondance des fonctions critiques** (multiplicité), **indépendance complète** des composants vis-à-vis de la production (indépendance), **test régulier des procédures** et **maintien en conditions de sécurité** (robustesse). |

## Pièges et confusions

- ⚠ Croire que l'exemple du rançongiciel est exhaustif alors qu'il n'illustre qu'une seule chaîne de scénario.
- ⚠ Oublier que la défaillance d'une barrière de protection de la production ne doit jamais faire perdre la visibilité de la supervision.
- ⚠ Réduire l'indépendance à des produits différents : il faut des socles technologiques distincts, sans faiblesses partagées, qui préservent aussi la résilience de l'administration.
- ⚠ Oublier que les mesures doivent être complétées pour couvrir l'ensemble des scénarios de risque possibles.

## Sigles et définitions

**Barrière** — Objectif de sécurité répondant à une étape d'un scénario de risque.

**Mesure** — Unité élémentaire, organisationnelle, technique ou opérationnelle, dont l'action participe à la couverture de l'objectif de sécurité d'une barrière.

**Sandbox** — Environnement isolé permettant d'analyser dynamiquement le comportement d'un fichier ou d'un courriel suspect sans risque pour le système d'information.

**EDR** — Endpoint Detection and Response, outil réalisant une analyse comportementale sur les postes utilisateurs pour détecter et bloquer l'installation de logiciels malveillants.

**Site de repli à froid** — Mesure de résilience consistant à disposer de fonctions critiques redondantes, indépendantes des composants de production, pour assurer la continuité d'activité.

## Auto-test

1. Quels sont les trois critères déterminant l'efficacité de la défense en profondeur ?
2. Quels sont les trois rôles d'une barrière ?
3. Comment appelle-t-on l'environnement isolé pour l'analyse dynamique ?
4. Que permet de réaliser un EDR ?
5. Quelle mesure de résilience utilise des fonctions critiques redondantes et indépendantes de la production ?

Réponses : **1.** La multiplicité, l'indépendance et la robustesse. · **2.** Protection avant l'attaque, défense pendant l'attaque, et résilience après l'attaque. · **3.** Une sandbox. · **4.** Une analyse comportementale sur les postes utilisateurs pour détecter et bloquer l'installation de logiciels malveillants. · **5.** Un site de repli à froid.

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.